

PREGLED PERMISIJA FAJLOVA

1.1 SETUID FAJLOVI

Komanda:

```
bash
```

```
find / -perm -4000 -ls 2>/dev/null
```

Šta se proverava:

Pronalazi sve fajlove koji imaju postavljen Setuid bit. Ovi fajlovi se izvršavaju sa privilegijama vlasnika fajla, bez obzira koji korisnik ih pokreće.

Bezbednosni problem:

Setuid fajlovi predstavljaju bezbednosni rizik jer ako napadač iskoristi ranjivost u setuid root fajlu, može odmah dobiti potpuni root pristup sistemu. Čak i legitimni setuid fajlovi ponekad mogu biti zloupotrebjeni.

Primer rizika:

Fajl `/bin/ping` ima setuid bit. Ako postoji ranjivost u ping komandi, napadač koji je iskoristi dobija root privilegije.

Legitimni setuid fajlovi (nisu problem):

- `/bin/passwd` - treba root za izmenu `/etc/shadow`
- `/bin/su` - treba root za promenu korisnika
- `/usr/bin/sudo` - treba root za eskalaciju privilegija

Rešenje:

Ukloniti setuid bit ako nije neophodan:

```
bash
```

```
sudo chmod u-s /putanja/do/fajla
```

1.2 FAJLOVI KOJE SVAKO MOŽE ČITATI I PISATI

Komanda:

bash

```
find / -type f -perm -006 2>/dev/null | grep -v '/proc'
```

Šta se proverava:

Pronalazi fajlove gde bilo koji korisnik na sistemu ima i dozvolu čitanja i dozvolu pisanja.

Bezbednosni problem:

Bilo koji korisnik može menjati ove fajlove. Ako je u pitanju konfiguracioni fajl, binarna datoteka ili skripta, napadač može da je izmeni da izvršava zlonamerni kod. Ako fajl sadrži osetljive podatke, bilo ko može da ga pročita.

Rešenje:

Ograničiti dozvole:

bash

```
sudo chmod 644 /putanja/do/fajla # vlasnik: čitanje/pisanje, ostali: samo čitanje
```

```
sudo chmod 600 /putanja/do/fajla # vlasnik: čitanje/pisanje, ostali: ništa
```

1.3 FAJLOVI KOJE SVAKO MOŽE PISATI

Komanda:

bash

```
find / -type f -perm -002 2>/dev/null | grep -v '/proc'
```

Šta se proverava:

Pronalazi fajlove gde bilo koji korisnik na sistemu ima dozvolu pisanja.

Bezbednosni problem:

Bilo koji korisnik može menjati ove fajlove bez ograničenja. Ovo je izuzetno opasno za

sistemske binarne fajlove, konfiguracione fajlove ili skripte. Napadač može zameniti ili izmeniti ove fajlove kako bi dobio neovlašćen pristup.

Rešenje:

```
bash
sudo chmod o-w /putanja/do/fajla
```

Za kritične sistemske fajlove:

```
bash
sudo chmod 644 /etc/passwd
sudo chmod 640 /etc/shadow
```

1.4 SIGURNOSNE KOPIJE OSETLJIVIH FAJLOVA

Komanda:

```
bash
ls -l /etc/shadow.backup 2>/dev/null
ls -la /backup/ 2>/dev/null

find / -name "*.backup" -o -name "*.old" -o -name "*.bak" 2>/dev/null
```

Šta se proverava:

Proverava da li postoje sigurnosne kopije osetljivih fajlova (npr. `/etc/shadow.backup`) koje možda imaju neograničene dozvole.

Bezbednosni problem:

Administratori često prave backup kopije osetljivih fajlova ali zaborave da ograniče dozvole. Čak i ako je originalni fajl sigurno podešen, backup kopija može biti čitljiva za sve korisnike. Napadač tada može da dođe do heševanih lozinki ili drugih osetljivih podataka.

Rešenje:

```
bash
```

```
sudo rm /etc/shadow.backup          # obrisati ako ne treba
sudo chmod 600 /etc/shadow.backup   # ili ograničiti dozvole

sudo chmod 700 /backup              # ograničiti pristup backup
direktorijumu
```

1.5 MOUNT OPCIJE PARTICIJA

Komanda:

```
bash

cat /etc/fstab | grep -v "^#"
```

Šta se proverava:

Proverava kako su particije montirane, posebno opcije `noatime`, `noexec` i `nosuid`.

Bezbednosni problemi:

1. `noatime` - ova opcija sprečava beleženje vremena poslednjeg pristupa fajlu. U slučaju bezbednosnog incidenta, ova informacija je važna za forenziku.
2. Nedostatak `noexec` na `/tmp` ili `/home` - bez `noexec`, korisnici mogu izvršavati binarne fajlove sa ovih lokacija. Napadač može upload-ovati malver i pokrenuti ga.
3. Nedostatak `nosuid` na `/tmp`, `/home`, `/dev` - bez `nosuid`, `setuid` bit na fajlovima na ovim particijama će biti poštovan. Napadač može upload-ovati `setuid` root fajl i dobiti root pristup.

Rešenje:

Izmeniti `/etc/fstab` i dodati odgovarajuće opcije:

```
text

/dev/sda1 /tmp ext4 defaults,noexec,nosuid 0 0

/dev/sda2 /home ext4 defaults,nosuid 0 0
```

Zatim remontovati particiju:

```
bash
```

```
sudo mount -o remount /tmp
```

PREGLED KORISNIKA I AUTENTIKACIJE

2.1 KORISNICI SA UID 0

Komanda:

```
bash  
awk -F: '($3 == 0) {print $1}' /etc/passwd
```

Šta se proverava:

Pronalazi sve korisnike koji imaju UID jednak 0.

Bezbednosni problem:

Na Linux sistemima, samo root treba da ima UID 0. Bilo koji drugi korisnik sa UID 0 ima potpuno iste privilegije kao root. Ovo je čest backdoor trik - napadač koji je već kompromitovao sistem može dodati novog korisnika sa UID 0 da zadrži pristup.

Rešenje:

```
bash  
# Promeniti UID korisnika  
sudo usermod -u 2000 problematicni_korisnik  
# Ili obrisati nalog  
  
sudo userdel -r problematicni_korisnik
```

2.2 KORISNICI SA SHELL PRISTUPOM

Komanda:

```
bash  
grep -E "/(bash|sh|zsh|dsh|tcsh)$" /etc/passwd
```

Šta se proverava:

Prikazuje sve korisnike koji imaju dodeljen shell (npr. `/bin/bash`) umesto `/bin/false` ili `/usr/sbin/nologin`.

Bezbednosni problem:

Servisni nalozi (kao što su `www-data`, `mysql`, `ntp`) ne treba da imaju shell pristup. Ako servisni nalog ima shell, napadač koji kompromituje taj servis može dobiti interaktivni pristup sistemu.

Rešenje:

```
bash  
sudo usermod -s /usr/sbin/nologin ime_servisnog_korisnika
```

2.3 ALGORITAM ZA HEŠOVANJE LOZINKI

Komanda:

```
bash  
awk -F: '{print $1 ":" $2}' /etc/shadow
```

Šta se proverava:

Analizira heš lozinki da identifikuje koji algoritam je korišćen.

Bezbednosni problem:

Različiti algoritmi imaju različitu otpornost na napade razbijanja lozinki:

Algoritam	Identifikator	Sigurnost
-----------	---------------	-----------

DES	nema  znaka	VRLO SLAB (8 karaktera, lako se razbija)
MD5		SLAB (brz za brute-force)
SHA-256		DOBAR
SHA-512		NAJBOLJI

Rešenje:

Promeniti podrazumevani algoritam u `/etc/pam.d/common-password` na `sha512`, zatim naterati korisnike da promene lozinke:

bash

```
sudo chage -d 0 korisnicko_ime
```

2.4 PODRAZUMEVANI ALGORITAM U PAM KONFIGURACIJI

Komanda:

bash

```
grep -E "pam_unix\\.so" /etc/pam.d/common-password
```

Šta se proverava:

Proverava koji je algoritam za hešovanje lozinke podešen kao podrazumevani.

Bezbednosni problem:

Čak i ako trenutne lozinke koriste dobar algoritam, ako je PAM podešen na slab algoritam, nove lozinke će biti hešovane slabim algoritmom. Na primer, sistem može imati stare lozinke u SHA-512 (dobro), ali ako je PAM podešen na MD5, sve nove lozinke će biti MD5 (slabo).

Rešenje:

Izmeniti `/etc/pam.d/common-password`:

text

```
password [success=1 default=ignore] pam_unix.so obscure sha512
```

2.5 KOMPLEKSNOŠT LOZINKI

Komanda:

bash

```
grep pam_cracklib.so /etc/pam.d/common-password
```

Šta se proverava:

Proverava da li je instaliran libpam-cracklib i koja su pravila za kompleksnost lozinke.

Bezbednosni problem:

Bez zahteva za kompleksnost, korisnici biraju slabe lozinke (npr. "password123", "admin", "123456") koje se lako razbijaju dictionary napadima.

Parametri:

- `minlen` - minimalna dužina lozinke (preporuka: 8)
- `difok` - koliko karaktera mora biti drugačije od stare lozinke (preporuka: 4)
- `ucredit` - zahtev za velika slova (preporuka: -1)
- `lcredit` - zahtev za mala slova (preporuka: -1)
- `dcredit` - zahtev za cifre (preporuka: -1)
- `ocredit` - zahtev za specijalne karaktere (preporuka: -1)

Rešenje:

Instalirati libpam-cracklib i dodati u `/etc/pam.d/common-password`:

bash

```
sudo apt-get install libpam-cracklib
```

Linija u konfiguracionom fajlu:

text


```
password requisite pam_cracklib.so retry=3 minlen=8 difok=4 ucredit=-1  
lcredit=-1 dcredit=-1 ocredit=-1
```

2.6 SUDO KONFIGURACIJA - NOPASSWD

Komanda:

```
bash  
  
grep -r "NOPASSWD" /etc/sudoers /etc/sudoers.d/ 2>/dev/null | grep -v "^#"
```

Šta se proverava:

Pronalazi sva sudo pravila koja ne zahtevaju lozinku.

Bezbednosni problem:

Ako korisnik može da izvršava komande sa sudo bez lozinke, bilo ko ko fizički dođe do njegovog otključanog terminala ili iskoristi neki drugi vektor napada može izvršavati privilegovane komande bez autentikacije.

Primer opasne konfiguracije:

```
text  
  
user ALL=(ALL) NOPASSWD: ALL
```

Ovo omogućava korisniku da izvršava bilo koju komandu kao bilo koji korisnik (uključujući root) bez lozinke.

Rešenje:

Ukloniti NOPASSWD iz /etc/sudoers:

```
bash  
  
sudo visudo  
  
# Izmeniti: user ALL=(ALL) ALL (traži lozinku)
```

2.7 OPASNE SUDO KOMANDE

Komanda:

bash

```
grep -r "chown\|chmod\|vi\|less\|find\|awk\|python" /etc/sudoers  
/etc/sudoers.d/
```

Šta se proverava:

Pronalazi sudo pravila koja dozvoljavaju izvršavanje komandi koje mogu biti zloupotrebene za dobijanje root pristupa.

Bezbednosni problem:

Čak i ako je korisniku dozvoljen samo ograničen skup komandi preko sudo-a, neke komande omogućavaju bekstvo do root shell-a.

Opasne komande i njihova zloupotreba:

Komanda	Kako napadač dobija root
<code>vi, less, more</code>	<code>./bin/bash</code> unutar editora
<code>find</code>	<code>find / -exec /bin/bash \;</code>
<code>awk</code>	<code>awk 'BEGIN {system("/bin/bash")}'</code>
<code>python, perl</code>	<code>python -c 'import pty; pty.spawn("/bin/bash")'</code>
<code>chown + chmod</code>	kopira <code>/bin/bash</code> , promeni vlasnika u root, doda setuid

Rešenje:

Nikada ne dozvoljavati ove komande preko sudo-a. Ako su neophodne, kreirati specifične skripte umesto davanja direktnog pristupa.

PREGLED MREŽE

3.1 MREŽNI INTERFEJSI

Komanda:

ip addr
ip -br addr

Šta se proverava:

Prikazuju se svi mrežni interfejsi na sistemu, njihove IP adrese i stanje interfejsa. Na primer, proverava se da li sistem koristi **eth0**, **wlan0**, **lo** ili neki drugi interfejs, kao i da li server ima IPv4 ili IPv6 adresu.

Bezbednosni problem:

Ako server ima neočekivan mrežni interfejs ili javnu IP adresu, može biti izložen mreži više nego što je planirano. Na primer, server koji treba da bude dostupan samo interno ne bi trebalo da ima javno dostupnu adresu. Takođe, ako je IPv6 aktivan, a firewall pravila su podešena samo za IPv4, moguće je da deo mrežne zaštite bude zaobiđen.

Primer rizika:

Server ima dobro podešena IPv4 firewall pravila, ali ima i aktivnu IPv6 adresu bez ikakvih IPv6 firewall pravila. Napadač može pokušati pristup servisima preko IPv6 adrese.

Rešenje:

Proveriti da li su svi aktivni interfejsi potrebni. Ako IPv6 nije potreban, može se isključiti. Ako jeste potreban, mora imati firewall pravila jednako stroga kao IPv4.

Primer provere IPv6 adresa:

ip -6 addr

3.2 RUTING TABELA

Komanda:

ip route
route -n

Šta se proverava:

Proverava se ruting tabela, odnosno pravila po kojima sistem odlučuje kuda šalje mrežne pakete.

Primer izlaza:

```
default via 10.0.2.1 dev eth0  
10.0.2.0/24 dev eth0
```

Prva linija znači da se sav saobraćaj koji nije namenjen lokalnoj mreži šalje preko gateway-a **10.0.2.1** kroz interfejs **eth0**.

Druga linija znači da se adrese iz lokalne mreže **10.0.2.0/24** šalju direktno preko interfejsa **eth0**, bez korišćenja gateway-a.

Bezbednosni problem:

Ruting tabela može pokazati da server ima pristup mrežama kojima ne bi trebalo da ima pristup. Ako napadač kompromituje server, može koristiti postojeće rute da se dalje kreće kroz mrežu.

Primer rizika:

Web server treba da prima samo HTTP/HTTPS zahteve sa interneta, ali ruting tabela pokazuje da ima pristup internoj mreži sa bazama podataka ili administrativnim sistemima.

Rešenje:

Ograničiti mrežni pristup servera samo na mreže koje su mu stvarno potrebne. Nepotrebne rute treba ukloniti ili ograničiti na nivou mrežne infrastrukture i firewall pravila.

3.3 DNS KONFIGURACIJA

Komanda:

```
cat /etc/resolv.conf
```

Šta se proverava:

Proverava se koje DNS servere sistem koristi za prevođenje domena u IP adrese.

Primer:

```
nameserver 8.8.8.8  
nameserver 1.1.1.1
```

Bezbednosni problem:

Ako sistem koristi nepoznat ili kompromitovan DNS server, zahtevi ka legitimnim domenima mogu biti preusmereni na pogrešne IP adrese. Ovo može dovesti do preuzimanja malicioznih paketa, slanja podataka pogrešnom serveru ili problema sa ažuriranjem sistema.

Primer rizika:

Server pokušava da pristupi update repozitorijumu, ali ga zlonamerni DNS preusmeri na lažni server.

Rešenje:

Koristiti pouzdane DNS servere. U produkcionim okruženjima preporučljivo je koristiti interne ili proverene DNS servere. Takođe, firewall treba da dozvoli DNS saobraćaj samo ka očekivanim DNS serverima.

3.4 LOKALNA MAPIRANJA U /etc/hosts

Komanda:

```
cat /etc/hosts
```

Šta se proverava:

Proverava se sadržaj fajla `/etc/hosts`. Ovaj fajl lokalno mapira imena hostova ili domena na IP adrese, pre nego što sistem koristi DNS.

Primer:

```
127.0.0.1 localhost
10.0.2.20 database.local
```

To znači da će sistem ime `database.local` prevoditi u IP adresu `10.0.2.20` bez korišćenja DNS servera.

Bezbednosni problem:

Ako napadač izmeni `/etc/hosts`, može lokalno preusmeriti legitiman domen na pogrešnu IP adresu. Ovo može dovesti do toga da server komunicira sa lažnim servisom.

Primer rizika:

U `/etc/hosts` se doda unos:

```
1.2.3.4 updates.example.com
```

Server će zatim misliti da se `updates.example.com` nalazi na IP adresi `1.2.3.4`, bez obzira na pravi DNS zapis.

Rešenje:

Proveriti da li su unosi u `/etc/hosts` očekivani. Dozvole nad fajlom treba da spreče obične korisnike da ga menjaju.

Primer dozvola:

```
ls -l /etc/hosts
```

Preporučeno je da fajl ne bude world-writable.

3.5 OTVORENI PORTOVI I SERVISI KOJI SLUŠAJU NA MREŽI

Komanda:

```
ss -tulpen  
lsof -i -n -P
```

Šta se proverava:

Prikazuju se servisi koji slušaju na TCP i UDP portovima. Cilj je da se vidi koji servisi su dostupni lokalno, a koji su dostupni sa mreže.

Primer servisa:

```
sshd sluša na portu 22  
apache2 sluša na portu 80  
mysqld sluša na portu 3306
```

Bezbednosni problem:

Svaki servis koji sluša na mreži povećava površinu napada. Posebno je opasno ako interni servisi, kao što su baze podataka, slušaju na svim adresama umesto samo lokalno.

Primer rizika:

```
MySQL sluša na:  
  
0.0.0.0:3306
```

To znači da baza može biti dostupna spolja, iako je koristi samo lokalna web aplikacija.

Rešenje:

Servisi treba da slušaju samo tamo gde je potrebno.

Primer za MySQL:

Ako bazu koristi samo lokalna aplikacija, u konfiguraciji treba podesiti:

```
bind-address = 127.0.0.1
```


Za javni web server očekivano je da HTTP/HTTPS portovi budu javno dostupni, ali SSH, baze podataka i interni servisi treba da budu ograničeni.

3.6 IPV4 FIREWALL PRAVILA

Komanda:

```
iptables -L -v -n  
iptables -S  
iptables-save
```

Šta se proverava:

Proveravaju se aktivna IPv4 firewall pravila. Posebno se proveravaju **INPUT**, **OUTPUT** i **FORWARD** lanci.

INPUT kontroliše saobraćaj koji ulazi na server.

OUTPUT kontroliše saobraćaj koji server šalje napolje.

FORWARD kontroliše saobraćaj koji server prosleđuje između mreža.

Bezbednosni problem:

Ako je **INPUT** policy podešen na **ACCEPT**, server prihvata dolazni saobraćaj osim ako nešto nije eksplicitno zabranjeno. To je slabiji model zaštite. Bolja praksa je da **INPUT** policy bude **DROP**, a da se zatim dozvole samo neophodni portovi.

Primer loše konfiguracije:

Chain INPUT policy ACCEPT

To znači da je ulazni saobraćaj podrazumevano dozvoljen.

Primer bolje konfiguracije:

Chain INPUT policy DROP

Zatim se eksplicitno dozvoljava:

- loopback saobraćaj
- HTTP/HTTPS za web server
- SSH samo sa administratorskih IP adresa
- RELATED, ESTABLISHED saobraćaj

Rešenje:

Podesiti firewall po principu najmanjih privilegija:

1. Podrazumevano blokirati dolazni saobraćaj.
 2. Dozvoliti samo potrebne portove.
 3. SSH ograničiti samo na trusted IP adrese ili VPN.
 4. Proveriti da li su pravila dovoljno precizna.
-

3.7 SSH PRISTUP KROZ FIREWALL

Komanda:

```
iptables -S INPUT | grep -- "--dport 22"  
ss -tulpen | grep ":22"
```

Šta se proverava:

Proverava se da li SSH servis sluša na mreži i da li firewall dozvoljava pristup SSH portu svima ili samo određenim IP adresama.

Bezbednosni problem:

SSH port je česta meta automatizovanih brute-force napada. Ako je port 22 otvoren celom internetu, napadači mogu konstantno pokušavati različite kombinacije korisničkih imena i lozinki.

Primer opasne konfiguracije:

```
-A INPUT -p tcp --dport 22 -j ACCEPT
```

Ovo dozvoljava SSH pristup sa bilo koje IP adrese.

Bolja konfiguracija:

Dozvoliti SSH samo sa administratorske IP adrese ili VPN mreže.

Primer:

```
-A INPUT -p tcp -s 203.0.113.10 --dport 22 -j ACCEPT
```

Rešenje:

Ograničiti SSH pristup na trusted IP adrese. Dodatno, preporučuje se zabrana direktnog root login-a i korišćenje SSH ključeva umesto lozinki.

3.8 OUTPUT FIREWALL PRAVILA

Komanda:

```
iptables -L OUTPUT -v -n  
iptables -S OUTPUT
```

Šta se proverava:

Proverava se odlazni saobraćaj, odnosno šta server sme da šalje ka drugim sistemima.

Bezbednosni problem:

Ako je **OUTPUT** policy podešen na **ACCEPT**, kompromitovan server može slobodno da komunicira sa spoljnim adresama. Napadač tada može lakše preuzimati dodatne alate, slati ukradene podatke ili komunicirati sa komandno-kontrolnim serverima.

Primer rizika:

Napadač kompromituje web aplikaciju i koristi server da pošalje podatke na spoljašnju IP adresu. Ako **OUTPUT** nije ograničen, firewall ga neće sprečiti.

Rešenje:

Ograničiti odlazni saobraćaj samo na ono što je serveru potrebno.

Za tipičan web server može biti potrebno dozvoliti:

- DNS ka poznatim DNS serverima
- NTP za sinhronizaciju vremena
- HTTP/HTTPS ka update repozitorijumima
- odgovore na već uspostavljene konekcije

Sve ostalo treba razmotriti i po potrebi blokirati.

3.9 PERSISTENT FIREWALL KONFIGURACIJA

Komanda:

```
iptables-save  
cat /etc/iptables.up.rules  
cat /etc/network/if-pre-up.d/iptables  
systemctl is-enabled netfilter-persistent  
systemctl is-enabled nftables  
systemctl is-enabled ufw
```

Šta se proverava:

Proverava se da li će firewall pravila ostati aktivna nakon restarta sistema.

Bezbednosni problem:

Firewall pravila koja su trenutno aktivna mogu nestati nakon restarta ako nisu sačuvana u persistent konfiguraciji. To znači da server trenutno može izgledati zaštićeno, ali posle ponovnog pokretanja može ostati otvoren.

Primer rizika:

Administrator ručno podesi iptables pravila, ali ih ne sačuva. Nakon restarta servera **INPUT** policy se vrati na **ACCEPT** i servisi postaju javno dostupni.

Rešenje:

Sačuvati firewall pravila i obezbediti da se automatski učitavaju pri pokretanju sistema.

Na Debian sistemima može se koristiti:

```
iptables-save > /etc/iptables.up.rules
```

Zatim se može podesiti skripta koja učitava pravila pre podizanja mreže:

```
/etc/network/if-pre-up.d/iptables
```

Primer sadržaja:

```
#!/bin/bash  
/sbin/iptables-restore < /etc/iptables.up.rules
```

Alternativno, mogu se koristiti alati kao što su `netfilter-persistent`, `nftables` ili `ufw`.

3.10 IPV6 FIREWALL PRAVILA

Komanda:

```
ip6tables -L -v -n  
ip6tables -S  
ip -6 addr
```

Šta se proverava:

Proverava se da li sistem koristi IPv6 i da li postoje IPv6 firewall pravila.

Bezbednosni problem:

Česta greška je da administrator dobro podesi IPv4 firewall, ali zaboravi IPv6. Ako server ima aktivnu IPv6 adresu, napadač može pokušati pristup servisima preko IPv6 mreže, zaobilazeći IPv4 pravila.

Primer loše konfiguracije:

IPv4 firewall:
INPUT DROP

IPv6 firewall:
INPUT ACCEPT

Ovo znači da je IPv4 zaštićen, ali IPv6 može biti otvoren.

Rešenje:

Ako IPv6 nije potreban, može se isključiti. Ako jeste potreban, **ip6tables** ili **nftables** pravila moraju biti podešena jednako strogo kao IPv4 pravila.

Minimalno treba proveriti:

- da li IPv6 ima globalnu adresu
 - da li je INPUT policy za IPv6 ACCEPT ili DROP
 - da li postoje eksplicitna pravila
 - da li su otvoreni isti servisi kao preko IPv4
-

PREGLED SISTEMA

4.1 IDENTIFIKACIJA OPERATIVNOG SISTEMA

Komanda:

bash

cat /etc/os-release

cat /etc/debian_version

lsb_release -a

Šta se proverava: Utvrđuje se distribucija Linux sistema i njena verzija. Različite distribucije imaju različite konfiguracione fajlove i različite životne cikluse podrške.

Bezbednosni problem: Ukoliko sistem koristi verziju distribucije koja više nije zvanično podržana (end-of-life), proizvođač više ne objavljuje sigurnosne ispravke. Nove ranjivosti koje se otkriju u jezgru ili sistemskim paketima ostaju zauvek nezakrpljene, pa svaki napadač sa javno dostupnim eksploitom može da kompromituje sistem.

Primer rizika: Server radi na Debian 9 (Stretch), čija je zvanična podrška završena. Objavljena je ranjivost u OpenSSH paketu, ali Debian više ne izdaje zakrpe za tu verziju. Sistem ostaje ranjiv sve dok se distribucija ne nadogradi.

Rešenje: Proveriti da li je verzija distribucije i dalje podržana. Ukoliko nije, planirati nadogradnju na noviju stabilnu verziju:

bash

sudo apt update && sudo apt full-upgrade

sudo do-release-upgrade

4.2 VERZIJA JEZGRA (KERNEL)

Komanda:

bash

uname -a

uname -r

uptime

Šta se proverava: Prikazuju se verzija jezgra, arhitektura sistema i vreme rada sistema od poslednjeg pokretanja.

Bezbednosni problem: Na osnovu verzije jezgra može se proveriti da li za nju postoje objavljene ranjivosti (npr. CVE baza). Distribucije obično primenjuju zakrpe bez menjanja major/minor broja verzije, pa je važno proveravati verziju u kontekstu konkretne distribucije. Visok uptime je snažan indikator da jezgro nije skoro ažurirano, jer se nove verzije jezgra primenjuju tek nakon restarta sistema.

Primer rizika: Komanda `uptime` pokazuje da server radi 180 dana bez restarta. Za to vreme objavljeno je nekoliko kritičnih ranjivosti u jezgru (npr. lokalna eskalacija privilegija). Iako su zakrpe instalirane, one nisu aktivne jer sistem nije restartovan.

Rešenje: Redovno ažurirati pakete jezgra i restartovati sistem nakon ažuriranja:

bash

`sudo apt update && sudo apt upgrade`

`sudo reboot`

4.3 UPRAVLJANJE VREMENOM

Komanda:

```
bash
```

```
cat /etc/timezone
```

```
timedatectl
```

```
ntpq -p -n
```

```
chronyc sources
```

Šta se proverava: Proverava se konfigurisana vremenska zona, da li je pokrenut servis za sinhronizaciju vremena (ntpd, chronyd ili systemd-timesyncd) i sa kojim NTP serverima sistem razmenjuje vreme.

Bezbednosni problem: Tačno vreme je preduslov za pouzdano vođenje logova, validaciju SSL/TLS sertifikata i autentikaciju koja zavisi od vremena (npr. Kerberos, TOTP). Ukoliko sistem nije sinhronizovan, korelacija logova između više sistema postaje nepouzdana, što ozbiljno otežava istragu bezbednosnih incidenata. Pored toga, korišćenje vremenske zone sa letnjim/zimskim računanjem vremena uvodi skokove u vremenu koji u logovima izgledaju kao da se događaji ponavljaju ili dešavaju u pogrešnom redosledu.

Primer rizika: Napadač je izvršio uspešan napad na server u 02:30 lokalnog vremena, baš u trenutku prelaska na letnje računanje vremena. Logovi različitih servisa pokazuju različita vremena za isti događaj, pa je nemoguće rekonstruisati redosled akcija napadača.

Rešenje: Koristiti UTC vremensku zonu i aktivnu NTP sinhronizaciju:

```
bash
```

```
sudo timedatectl set-timezone UTC
```

```
sudo systemctl enable --now systemd-timesyncd
```

4.4 INSTALIRANI PAKETI

Komanda:

bash

dpkg -l

rpm -qa

apt list --upgradable

Šta se proverava: Prebrojavaju se instalirani paketi, identifikuju se paketi koji se ne očekuju na produkcionom serveru i proverava se da li postoje raspoloživa sigurnosna ažuriranja.

Bezbednosni problem: Svaki nepotreban paket povećava napadnu površinu sistema. Server koji ima ulogu veb servera ne treba da poseduje grafičko okruženje, razvojne alate (gcc, gdb) niti zastarele alate za udaljen pristup (telnet, rsh). Pored toga, nezakrpljena sigurnosna ažuriranja direktno znače da je sistem ranjiv na poznate, javno objavljene eksploite, koje napadači automatski skeniraju.

Primer rizika: Na veb serveru je instaliran gcc kompajler. Napadač koji dobije ograničen pristup sistemu može lokalno kompajlirati exploit za eskalaciju privilegija direktno na serveru, umesto da ga unosi preko mreže.

Rešenje: Ukloniti nepotrebne pakete i redovno primenjivati sigurnosna ažuriranja:

bash

sudo apt purge ime_paketa

sudo apt update && sudo apt upgrade

sudo unattended-upgrade

4.5 LOGOVANJE (LOGGING)

Komanda:

bash

```
ps -ef | grep -E "rsyslog|syslog-ng|journald"
```

```
cat /etc/rsyslog.conf
```

```
ls -l /etc/logrotate.d/
```

Šta se proverava: Utvrđuje se koji je servis za logovanje aktivan, kakve su podrazumevane dozvole nad log fajlovima, da li se logovi šalju na udaljeni sistem i da li sistem prihvata logove sa mreže.

Bezbednosni problem: Logovi koji se čuvaju isključivo lokalno mogu biti obrisani ili izmenjeni od strane napadača koji je kompromitovao sistem, čime se uklanjaju tragovi napada. Slanje logova na udaljeni log server predstavlja osnovnu meru zaštite integriteta logova. Sa druge strane, ukoliko sistem nepotrebno prihvata logove sa mreže, otvara dodatni napadni vektor (port 514 dostupan napolju).

Primer rizika: Napadač je kompromitovao server, izvršio napad i potom obrisao `/var/log/auth.log` kako bi prikrio tragove. Pošto logovi nisu prosleđivani na udaljeni log server, ne postoji nijedan zapis o tome kako je napadač ušao u sistem.

Rešenje: Konfigurisati prosleđivanje logova na udaljeni log server u `/etc/rsyslog.conf`:

text

```
*.* @logserver.local:514    # UDP prosleđivanje
```

```
*.* @@logserver.local:514   # TCP prosleđivanje (pouzdanije)
```

Onemogućiti prihvatanje logova sa mreže ako sistem nije log server (zakomentarisati linije `$ModLoad imudp` i `$ModLoad imtcp`).

PREGLED SERVISA

5.1 POKRENUTI SERVISI

Komanda:

```
bash
ps -ef
systemctl list-units --type=service --state=running
```

Šta se proverava: Identifikuju se svi servisi i procesi koji su trenutno aktivni na sistemu, kao i njihovi vlasnici (root, www-data, mysql i drugi).

Bezbednosni problem: Svaki pokrenuti servis povećava napadnu površinu sistema. Servisi koji nisu neophodni za funkcionisanje aplikacije ne bi trebalo da budu pokrenuti. Posebno je opasno kada servisi koji su izloženi mreži rade pod nalogom **root**, jer u tom slučaju eksploatacija ranjivosti u samom servisu odmah daje napadaču potpune privilegije na sistemu.

Primer rizika: Na veb serveru je pokrenut i FTP servis koji nije neophodan. Napadač iskorišćava javno objavljenu ranjivost FTP servisa i dobija pristup sistemu, iako sam veb server nema nikakvih bezbednosnih propusta.

Rešenje: Zaustaviti i onemogućiti pokretanje nepotrebnih servisa pri startovanju sistema:

```
bash
sudo systemctl stop ime_servisa
sudo systemctl disable ime_servisa
```

5.2 OTVORENI PORTOVI I SERVISI KOJI SLUŠAJU

Komanda:

```
bash
ss -tulpen
lsuf -i -n -P
```

Šta se proverava: Prikazuju se TCP i UDP portovi na kojima servisi slušaju, kao i adresa na kojoj slušaju (0.0.0.0, 127.0.0.1 ili konkretna IP adresa).

Bezbednosni problem: Servisi koji slušaju na svim mrežnim interfejsima (0.0.0.0) dostupni su sa mreže, čak i kada to nije potrebno. Interni servisi poput baza podataka, redis-a ili mongo-a ne treba da budu izloženi mreži ukoliko im pristupa samo lokalna aplikacija sa istog servera.

Primer rizika: MySQL sluša na 0.0.0.0:3306 iako mu pristupa samo lokalna PHP aplikacija. Napadač sa interneta može pokušati direktan brute-force napad na MySQL nalog root, zaobilazeći potpuno veb aplikaciju.

Rešenje: U konfiguraciji servisa eksplicitno postaviti bind-address = 127.0.0.1 za servise koji se koriste samo lokalno. Dodatno, ograničiti pristup firewall pravilima:

```
bash
sudo iptables -A INPUT -p tcp --dport 3306 -s 127.0.0.1 -j ACCEPT
sudo iptables -A INPUT -p tcp --dport 3306 -j DROP
```

5.3 OPENSSSH KONFIGURACIJA

Komanda:

```
bash
cat /etc/ssh/sshd_config
grep -E "PermitRootLogin|Protocol|Port|PasswordAuthentication" /etc/ssh/sshd_config
```

Šta se proverava: Proveravaju se ključne SSH konfiguracione opcije: dozvoljen direktan root login, korišćena verzija protokola, port na kome SSH sluša, način autentikacije i opcija TCP prosleđivanja.

Bezbednosni problem: Podrazumevana vrednost opcije `PermitRootLogin` je `yes`, što znači da napadač može direktno pokušati brute-force napad na root nalog. Korišćenje SSH protokola verzije 1 je izuzetno opasno zbog poznatih kriptografskih slabosti. Korišćenje podrazumevanog porta 22 čini sistem metom automatizovanih skenera. Autentikacija lozinkom je znatno slabija od autentikacije SSH ključem.

Primer rizika: SSH server radi sa `PermitRootLogin yes` i `PasswordAuthentication yes` na portu 22. Automatizovani botovi iz celog sveta neprestano pokušavaju kombinacije najčešćih root lozinki. Dovoljna je jedna slaba lozinka da napadač dobije potpun pristup serveru.

Rešenje: Izmeniti `/etc/ssh/sshd_config`:

```
text
PermitRootLogin no
Protocol 2
Port 2222
PasswordAuthentication no
AllowTcpForwarding no
PermitEmptyPasswords no
```

Restartovati SSH servis i ne zaboraviti da se isti port otvori u firewall-u:

```
bash
sudo systemctl restart sshd
```


5.4 MYSQL/MARIADB KONFIGURACIJA

Komanda:

```
bash
```

```
cat /etc/mysql/my.cnf
```

```
mysql -u root -e "SELECT user, host, authentication_string FROM mysql.user;"
```

```
mysql -u root -e "SELECT user, file_priv FROM mysql.user WHERE file_priv='Y';"
```

Šta se proverava: Proverava se na kojim adresama baza sluša, da li root korisnik baze ima postavljenu lozinku, koji algoritam se koristi za heširanje lozinki naloga u bazi i koji nalozi imaju **FILE** privilegiju.

Bezbednosni problem: Ukoliko baza sluša na svim interfejsima a koristi je samo lokalna aplikacija, ona je nepotrebno izložena mreži. MySQL ima sopstveni root nalog odvojen od sistemskog root naloga, i česta je greška da on nema postavljenu lozinku. Privilegija **FILE** omogućava korisniku baze da čita i piše fajlove na sistemu kroz SQL upite, što napadaču koji kompromituje samo aplikacioni nalog daje dodatne mogućnosti.

Primer rizika: WordPress aplikacija se povezuje sa MySQL bazom preko naloga **wordpress** koji ima privilegiju **FILE**. Napadač eksploatiše SQL injection u WordPress plugin-u i, iako je dobio pristup samo bazi, koristi **SELECT ... INTO OUTFILE** da napiše PHP webshell direktno u **/var/www/** direktorijum.

Rešenje: U **/etc/mysql/my.cnf** u sekciji **[mysqld]**:

```
text
```

```
bind-address = 127.0.0.1
```

Ukloniti nepotrebne privilegije sa aplikacionog naloga:

```
sql
```

```
REVOKE FILE ON *.* FROM 'wordpress'@'localhost';
```

```
FLUSH PRIVILEGES;
```

Postaviti jaku lozinku za root nalog baze:

```
bash
```

```
sudo mysql_secure_installation
```

5.5 APACHE KONFIGURACIJA

Komanda:

bash

```
cat /etc/apache2/apache2.conf
```

```
grep -E "ServerTokens|ServerSignature" /etc/apache2/conf.d/security
```

```
grep -rE "Options.*Indexes" /etc/apache2/sites-enabled/
```

Šta se proverava: Proverava se pod kojim korisničkim nalogom radi Apache, da li je u zaglavlјima HTTP odgovora izložena verzija servera, da li je uključeno listanje direktorijuma i kakve su dozvole nad fajlovima u document root direktorijumu.

Bezbednosni problem: Ukoliko Apache radi pod `root` nalogom, eksploatacija bilo koje ranjivosti u samom serveru ili u hostovanim aplikacijama daje napadaču potpuni pristup sistemu. Otkrivanje tačne verzije Apache-a u HTTP zaglavlјima omogućava napadaču da odmah pretražuje baze ranjivosti za tu konkretnu verziju. Uključeno listanje direktorijuma može otkriti backup fajlove, konfiguracione fajlove ili druge osetljive resurse koji nisu eksplicitno linkovani sa veb stranice.

Primer rizika: Apache šalje zaglavlje `Server: Apache/2.4.29 (Ubuntu)`. Napadač pretražuje CVE bazu, pronalazi javno objavljen exploit za tu verziju i odmah ga koristi protiv servera. Dodatno, direktorijum `/wp-admin/images/` ima uključeno listanje, pa napadač vidi sve fajlove unutra uključujući i zaboravljen `backup.sql`.

Rešenje: U `/etc/apache2/conf.d/security` (ili `/etc/apache2/conf-enabled/security.conf`):

text

```
ServerTokens Prod
```

```
ServerSignature Off
```

U konfiguraciji sajta zameniti `Indexes` sa `-Indexes`:

text

```
<Directory /var/www/html/>
```

```
Options -Indexes FollowSymLinks
```

```
</Directory>
```

Restartovati Apache:

bash

`sudo` systemctl restart apache2

5.6 PREGLED CRONTAB ZADATAKA

Komanda:

```
bash
cat /etc/crontab
ls -la /etc/cron.d/
ls -la /var/spool/cron/crontabs/
crontab -u root -l
```

Šta se proverava: Proveravaju se zakazani zadaci koji se automatski izvršavaju, kao i dozvole nad skriptama koje ti zadaci pokreću.

Bezbednosni problem: Crontab često pokreće skripte pod root privilegijama. Ukoliko bilo koja takva skripta ima dozvole pisanja za sve korisnike (world-writable), bilo koji korisnik na sistemu može izmeniti njen sadržaj. Pri sledećem automatskom pokretanju, izmenjeni kod će se izvršiti pod privilegijama vlasnika cron zadatka, čime se postiže eskalacija privilegija do root nivoa.

Primer rizika: U root crontab-u zakazano je svakodnevno pokretanje skripte `/root/backup.sh`, ali sam fajl ima dozvole `777`. Običan korisnik dodaje u skriptu liniju koja kreira nalog sa UID 0 i čeka da skripta odradi svoj sledeći ciklus. Naredne noći, napadač ima trajni root pristup sistemu.

Rešenje: Ograničiti dozvole nad svim skriptama koje se pokreću iz cron-a:

```
bash
sudo chmod 700 /root/backup.sh
sudo chown root:root /root/backup.sh
```

Izbegavati zakazivanje osetljivih poslova između 02:00 i 03:00 zbog mogućih problema sa prelaskom na letnje/zimsko vreme.